

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 01

Domain I - Information Security Governance

27 Questions	43 Minutes	Single Best Answer Format
------------------------	----------------------	-------------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 43 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM1-001)

Which statement **BEST** describes the relationship between information security governance and enterprise governance?

- A. Information security governance operates independently to preserve technical objectivity.
- B. Information security governance is integrated with enterprise governance to support objectives and manage risk.
- C. Enterprise governance applies to financial decisions, while security governance applies to technology decisions.
- D. Information security governance replaces enterprise risk governance for information-related matters.

Question 2 (CISM1-002)

Scenario: A rapidly growing design company relies on autonomous teams and informal decision-making. A newly introduced security governance model requires every minor exception to be approved by a central committee, causing teams to bypass the process.

What is the **MOST** likely cause of the governance model's poor adoption?

- A. The company has not deployed enough preventive security controls.
- B. The committee does not include an external compliance adviser.
- C. The exception process does not require approval from internal audit.
- D. The centralized approval model conflicts with the organization's operating culture.

Question 3 (CISM1-003)

Scenario: A regional health services provider is entering a jurisdiction with new privacy requirements. The security manager has identified several obligations that affect business processes, technology, and third-party contracts.

What should the security manager do **FIRST** to establish effective governance over these obligations?

- A. Map the obligations to accountable business owners and required organizational controls.
- B. Purchase a compliance monitoring platform for the new jurisdiction.
- C. Assign all compliance decisions to the information security department.
- D. Ask each technology team to interpret the requirements independently.

Question 4 (CISM1-004)

What is the PRIMARY governance purpose of segregation of duties?

- A. To ensure all critical tasks are performed by senior employees
- B. To eliminate the need for monitoring privileged activities
- C. To prevent one individual from controlling incompatible stages of a process
- D. To transfer accountability from process owners to control operators

Question 5 (CISM1-005)

***Scenario:** Following a merger, two business units retain separate security committees. Both committees can approve risk exceptions for a shared customer platform, and they recently issued conflicting decisions.*

What is the BEST governance response?

- A. Allow the platform administrator to select the decision that is easiest to implement.
- B. Establish one accountable risk owner and a documented escalation path for the shared platform.
- C. Require both committees to approve every operational change affecting the platform.
- D. Ask internal audit to assume ownership of all platform risk decisions.

Question 6 (CISM1-006)

***Scenario:** A manufacturer is redesigning its order-to-delivery operating model. Enterprise architects are selecting new information flows, applications, and service providers before consulting the security function.*

What is the MOST appropriate action for the information security manager?

- A. Establish security participation and risk criteria within architecture governance decisions.
- B. Develop the detailed application architecture independently of the architecture team.
- C. Delay security involvement until technical designs are ready for control testing.
- D. Require the existing security architecture to remain unchanged throughout the transformation.

Question 7 (CISM1-007)

Which governance arrangement BEST demonstrates accountability for an information security control?

- A. Several teams may independently decide whether the control is necessary.
- B. Internal audit operates the control and evaluates its own performance.
- C. The security manager becomes accountable for every control across the enterprise.
- D. A designated owner answers for outcomes while assigned personnel perform the control.

Question 8 (CISM1-008)

Scenario: A major customer asks a logistics company to accept security commitments that exceed current capabilities. The contract would produce significant revenue, but meeting the commitments would require substantial investment and operational change.

Which recommendation should the information security manager make?

- A. Accept the terms because customer contracts always take precedence over internal risk limits.
- B. Reject the contract because security commitments should never require new investment.
- C. Present the capability gaps, risk exposure, treatment options, and business impact to the authorized decision-makers.
- D. Permit the sales team to accept the terms and document any exceptions after signing.

Question 9 (CISM1-009)

Scenario: The board receives a monthly report containing vulnerability counts, blocked network connections, and software update statistics. Directors say the report does not help them determine whether security supports the enterprise's objectives.

How should the information security manager improve the report?

- A. Link security risk and performance trends to enterprise objectives and risk appetite.
- B. Add more detailed technical data for every business system.
- C. Report only incidents that have already caused a financial loss.
- D. Replace the report with an annual external penetration test summary.

Question 10 (CISM1-010)

Scenario: A financial cooperative plans to consolidate customer data into a shared enterprise platform. Business leaders expect the security manager to approve the target architecture and accept all residual information risk.

What is the BEST response from the security manager?

- A. Accept ownership because the platform contains security controls.
- B. Define requirements and advise the accountable owner on residual risk.
- C. Transfer all architecture decisions to the external platform provider.
- D. Limit involvement to testing the platform after implementation.

Question 11 (CISM1-011)

What is the PRIMARY purpose of an information security strategy?

- A. To prescribe detailed configurations for all enterprise technologies
- B. To replace the enterprise strategy for information-dependent operations
- C. To align security capabilities and initiatives with enterprise objectives and risk.
- D. To document every security procedure performed by operational teams

Question 12 (CISM1-012)

Scenario: A security plan lists projects to deploy identity tools, classify data, and revise supplier reviews, but it does not state what business or risk outcomes the projects are expected to achieve.

Which element is MOST clearly missing?

- A. Detailed configuration baselines for each proposed technology
- B. Individual performance ratings for project personnel
- C. An inventory of all historical security incidents
- D. Objectives tied to enterprise goals and risk priorities.

Question 13 (CISM1-013)

Scenario: An online education company plans to expand internationally and use local partners to process student information. Its current security strategy assumes domestic operations and centrally managed processing.

What should the information security manager analyze FIRST?

- A. Whether the existing security team prefers centralized administration
- B. How new legal, market, threat, and partner conditions affect security objectives and capabilities
- C. Which security product has the largest number of available features
- D. Whether all partners can adopt the company's current technical configurations unchanged

Question 14 (CISM1-014)

Scenario: A retailer has approved a goal to make digital sales resilient during peak seasons. Security leaders know the current environment has inconsistent recovery capabilities, but no improvement roadmap exists.

What should the information security manager do NEXT?

- A. Compare current capabilities with the resilience objective and prioritize the resulting gaps.
- B. Purchase additional recovery infrastructure before defining target capabilities.
- C. Copy the resilience roadmap used by a larger retailer.
- D. Measure success solely by the number of recovery technologies deployed.

Question 15 (CISM1-015)

Scenario: A utility has funding for only one of three proposed security initiatives this year. One addresses a risk near the approved tolerance threshold, another supports a critical modernization dependency and reduces greater aggregate exposure, and the third resolves numerous low-impact audit observations.

Which initiative should receive the HIGHEST priority?

- A. The initiative with the most visible technology improvements
- B. The initiative addressing the greatest number of audit observations
- C. The dependency offering the strongest risk reduction and business enablement.
- D. The initiative proposed first in the annual planning cycle

Question 16 (CISM1-016)

Scenario: An insurance company has a low appetite for disruption to claims processing. The proposed security roadmap postpones resilience improvements for three years while funding several lower-impact administrative enhancements.

What is the information security manager's BEST course of action?

- A. Approve the roadmap because all listed projects provide some security value.
- B. Treat risk appetite as relevant only when an incident occurs.
- C. Ask operations to fund resilience outside the governance process.
- D. Reprioritize and show how the delay conflicts with approved risk appetite.

Question 17 (CISM1-017)

Scenario: A midsize nonprofit wants a structured information security governance approach. Leaders propose implementing every practice from a comprehensive framework despite limited staffing and a relatively simple operating model.

What should the information security manager recommend?

- A. Reject all frameworks because they are unsuitable for smaller organizations.
- B. Tailor relevant framework practices to the nonprofit's objectives, risks, resources, and obligations.
- C. Implement the entire framework before addressing any current security gaps.
- D. Select practices solely according to what the existing security tools can automate.

Question 18 (CISM1-018)

Scenario: A transportation company has a strategic objective to reduce disruption from third-party service failures. The dashboard currently reports only how many supplier questionnaires were completed.

Which additional measure would BEST indicate progress toward the objective?

- A. The total number of questions in the supplier questionnaire
- B. The number of employees assigned to procurement
- C. Critical suppliers meeting resilience requirements and closing material gaps on time.
- D. The number of security terms defined in the supplier policy

Question 19 (CISM1-019)

Scenario: A bank will replace several legacy applications with shared digital services over four years. The security function proposes a large investment to enhance controls in each legacy application without considering the approved target architecture.

What should the information security manager do FIRST?

- A. Align investments with transition risks, target capabilities, and the architecture roadmap.
- B. Cancel all security spending on systems scheduled for eventual replacement.
- C. Fund every legacy enhancement to preserve identical control levels.
- D. Allow application owners to invest independently without strategic coordination.

Question 20 (CISM1-020)

Scenario: Executives have rejected a proposed identity modernization program because the request describes technical deficiencies but does not explain its enterprise value.

How should the information security manager revise the proposal?

- A. Add extensive technical diagrams showing every system connection.
- B. Emphasize that security recommendations should be funded without financial review.
- C. Base the request primarily on the age of the current technology.
- D. Quantify expected risk reduction, business enablement, costs, dependencies, and implementation options.

Question 21 (CISM1-021)

Which artifact BEST communicates the sequencing, dependencies, timing, and ownership of initiatives used to implement an information security strategy?

- A. A technical configuration standard
- B. An information security roadmap
- C. An individual incident record
- D. A vulnerability scan report

Question 22 (CISM1-022)

Scenario: A global manufacturer lacks enough specialists to operate a planned monitoring capability across all regions. One proposal outsources the entire capability, while another builds it internally over several years. Executives need a recommendation that supports the strategy without obscuring accountability.

Which approach should the information security manager take?

- A. Select outsourcing because external providers always deliver stronger security.
- B. Select internal delivery because security responsibilities cannot be sourced.
- C. Compare sourcing options against required outcomes, risk, cost, skills, oversight needs, and transition constraints.
- D. Choose the least expensive option and allow the provider to define acceptable risk.

Question 23 (CISM1-023)

Scenario: Senior leaders approved a three-year security strategy, but participation in quarterly steering meetings has declined because discussions focus on project details and technical issues.

What should the information security manager do to restore continuing sponsorship?

- A. Refocus meetings on business outcomes, material risks, decisions needed, and progress against strategic commitments.
- B. Increase the frequency of detailed technical status presentations.
- C. Remove business leaders from the steering group and invite only security specialists.
- D. Suspend governance meetings until the next annual budget cycle.

Question 24 (CISM1-024)

Scenario: A media company reports that all planned security projects were delivered on schedule, yet unauthorized exposure of sensitive content continues to rise. The existing metrics emphasize project completion and spending.

What is the MOST appropriate conclusion?

- A. The strategy is effective because all projects were completed.
- B. The company should stop measuring security until exposure stabilizes.
- C. The project teams should receive additional funding without further analysis.
- D. The strategy should be reviewed because its outputs are not reducing risk.

Question 25 (CISM1-025)

Scenario: A diversified company has hundreds of technical procedures but no enterprise information security policy. Business units disagree about who may grant exceptions and which requirements apply across the organization.

What would BEST address the underlying governance weakness?

- A. A larger library of detailed operating procedures
- B. A separate security policy written by each system administrator
- C. An approved enterprise policy defining principles, authority, accountability, and supporting-document hierarchy.
- D. A temporary freeze on all business unit technology changes

Question 26 (CISM1-026)

Scenario: A software company shifts from selling installed products to operating a subscription service. Its security strategy still focuses primarily on protecting internal development systems and does not address continuous customer service delivery.

What should the information security manager do FIRST?

- A. Preserve the existing strategy until all subscription systems are operational.
- B. Reassess dependencies, risks, and capabilities created by the new service model.
- C. Delegate the security strategy entirely to the subscription platform engineers.
- D. Add isolated technical controls without changing strategic objectives.

Question 27 (CISM1-027)

Scenario: During an annual strategy review, product leaders favor faster market entry, regulators expect stronger oversight, enterprise architects are consolidating platforms, and the security team wants to address accumulated control weaknesses. Available funding cannot satisfy every request.

What is the BEST way for the information security manager to develop the revised roadmap?

- A. Evaluate needs against objectives, obligations, risk appetite, architecture dependencies, and expected value.
- B. Give equal funding to each stakeholder group regardless of risk or dependency.
- C. Prioritize only the security team's control weaknesses because they are already documented.
- D. Allow the stakeholder with the largest budget to establish enterprise security priorities.

Answer Key

Domain I - Information Security Governance

1 B	2 D	3 A	4 C	5 B
6 A	7 D	8 C	9 A	10 B
11 C	12 D	13 B	14 A	15 C
16 D	17 B	18 C	19 A	20 D
21 B	22 C	23 A	24 D	25 C
26 B	27 A			

Detailed Explanations

Question 1 (CISM1-001)

Correct answer: B - Information security governance is integrated with enterprise governance to support objectives and manage risk.

Information security governance should be integrated with enterprise governance so security priorities, accountability, and risk decisions support business objectives. Operating independently can create misalignment, limiting enterprise governance to finance ignores its broader scope, and security governance contributes to rather than replaces enterprise risk governance.

Question 2 (CISM1-002)

Correct answer: D - The centralized approval model conflicts with the organization's operating culture.

A governance design that conflicts with an organization's decentralized culture is likely to be bypassed. Preventive controls do not resolve an unsuitable decision model, an external adviser is not inherently necessary, and internal audit should provide assurance rather than approve routine exceptions.

Question 3 (CISM1-003)

Correct answer: A - Map the obligations to accountable business owners and required organizational controls.

Mapping obligations to accountable owners and controls establishes responsibility across the affected functions before implementation decisions are made. A platform cannot define ownership, the security department should not own every business compliance decision, and independent interpretations could produce inconsistent obligations and controls.

Question 4 (CISM1-004)

Correct answer: C - To prevent one individual from controlling incompatible stages of a process

Segregation of duties reduces the risk of error, abuse, or concealment by dividing incompatible responsibilities. Seniority does not remove conflicts, monitoring remains necessary, and process owners retain accountability even when others operate controls.

Question 5 (CISM1-005)

Correct answer: B - Establish one accountable risk owner and a documented escalation path for the shared platform.

A shared asset requires clear accountability, decision rights, and escalation to prevent conflicting risk treatment. An administrator lacks business risk authority, unanimous approval can create delays without resolving ownership, and internal audit must remain independent rather than own management decisions.

Question 6 (CISM1-006)

Correct answer: A - Establish security participation and risk criteria within architecture governance decisions.

Security participation and risk criteria should be embedded in architecture governance while business capabilities and information flows are being designed. The security manager should not independently own detailed application architecture, late testing misses strategic design choices, and freezing the existing architecture may obstruct legitimate transformation.

Question 7 (CISM1-007)

Correct answer: D - A designated owner answers for outcomes while assigned personnel perform the control.

Accountability rests with a clearly designated owner who answers for the outcome, while responsibility for performing activities may be delegated. Independent team decisions weaken consistency, audit should not assess its own operations, and enterprise control accountability should remain with appropriate business or process owners rather than defaulting entirely to security.

Question 8 (CISM1-008)

Correct answer: C - Present the capability gaps, risk exposure, treatment options, and business impact to the authorized decision-makers.

Authorized leaders need a risk-informed view of capability gaps, costs, benefits, and treatment options before accepting the commitment. Contract terms do not automatically override risk limits, rejecting all investment-dependent commitments ignores business value, and documenting exceptions after signing could leave the company bound to obligations it cannot meet.

Question 9 (CISM1-009)

Correct answer: A - Link security risk and performance trends to enterprise objectives and risk appetite.

Board reporting should connect security exposure, performance, and investment outcomes to business objectives and approved risk appetite. More technical detail can obscure governance decisions, realized losses alone omit emerging exposure, and a penetration test is too narrow to replace continuing governance reporting.

Question 10 (CISM1-010)

Correct answer: B - Define requirements and advise the accountable owner on residual risk.

The security manager should provide requirements, analysis, and advice within architecture governance, while the accountable business owner makes authorized residual-risk decisions. Security controls do not transfer business ownership, providers cannot own the enterprise's decisions, and post-implementation testing is too late to guide the target architecture.

Question 11 (CISM1-011)

Correct answer: C - To align security capabilities and initiatives with enterprise objectives and risk.

An information security strategy establishes direction for capabilities and initiatives that support enterprise goals and manage risk. Detailed configurations and procedures belong in lower-level standards or operating documentation, while the security strategy must align with rather than replace enterprise strategy.

Question 12 (CISM1-012)

Correct answer: D - Objectives tied to enterprise goals and risk priorities.

Projects become strategically meaningful when they support measurable objectives tied to enterprise goals and risk priorities. Configuration baselines are operational, personnel ratings do not define strategy, and incident history may inform analysis but cannot substitute for desired outcomes.

Question 13 (CISM1-013)

Correct answer: B - How new legal, market, threat, and partner conditions affect security objectives and capabilities

International expansion changes the external environment, so the manager should assess how legal obligations, threats, markets, and partners affect strategic requirements. Team preference is secondary, product features should follow identified needs, and identical configurations may not fit different partner or jurisdictional contexts.

Question 14 (CISM1-014)

Correct answer: A - Compare current capabilities with the resilience objective and prioritize the resulting gaps.

A current-to-desired-state comparison identifies the capability gaps that should drive prioritized initiatives and a roadmap. Immediate purchasing precedes defined requirements, another organization's roadmap may not fit the retailer, and technology counts do not measure whether the business resilience objective is achieved.

Question 15 (CISM1-015)

Correct answer: C - The dependency offering the strongest risk reduction and business enablement.

The modernization dependency offers the strongest combination of enterprise value, material risk reduction, and strategic enablement. Technology visibility and proposal timing are weak prioritization criteria, while a high count of low-impact observations does not outweigh aggregate exposure and critical business dependencies.

Question 16 (CISM1-016)

Correct answer: D - Reprioritize and show how the delay conflicts with approved risk appetite.

The roadmap should be reconsidered because delaying protection of a critical process conflicts with the enterprise's stated appetite for disruption. General security value does not establish proper priority, appetite guides prospective decisions rather than only incident response, and bypassing governance obscures enterprise tradeoffs.

Question 17 (CISM1-017)

Correct answer: B - Tailor relevant framework practices to the nonprofit's objectives, risks, resources, and obligations.

Governance frameworks should be tailored to organizational objectives, risk, obligations, and available resources. Rejecting all frameworks loses useful structure, wholesale implementation may consume resources without proportional value, and existing tools should not determine governance priorities.

Question 18 (CISM1-018)

Correct answer: C - Critical suppliers meeting resilience requirements and closing material gaps on time.

Measuring critical suppliers that meet resilience requirements and remediate material gaps connects activity to the desired reduction in disruption exposure. Questionnaire length, procurement staffing, and policy terminology are input or administrative measures that do not demonstrate the strategic outcome.

Question 19 (CISM1-019)

Correct answer: A - Align investments with transition risks, target capabilities, and the architecture roadmap.

Investment decisions should account for transition exposure, required target capabilities, and the timing of architectural change. Canceling all legacy spending may leave unacceptable interim risk, funding every enhancement can waste resources, and independent investments can create duplication and incompatibility.

Question 20 (CISM1-020)

Correct answer: D - Quantify expected risk reduction, business enablement, costs, dependencies, and implementation options.

A decision-ready business case connects the investment to risk reduction, enterprise benefits, costs, dependencies, and alternatives. Detailed diagrams may support implementation but do not establish value, security investments still require governance review, and technology age alone is not a sufficient strategic justification.

Question 21 (CISM1-021)

Correct answer: B - An information security roadmap

A roadmap translates strategic direction into sequenced initiatives with dependencies, timing, and ownership. Configuration standards define technical expectations, while incident records and scan reports provide operational information rather than an implementation path for the strategy.

Question 22 (CISM1-022)

Correct answer: C - Compare sourcing options against required outcomes, risk, cost, skills, oversight needs, and transition constraints.

The sourcing decision should compare how each option meets strategic outcomes while considering risk, total cost, capability, oversight, and transition needs. Neither external nor internal delivery is universally superior, and a provider can perform services but cannot define the enterprise's risk acceptance.

Question 23 (CISM1-023)

Correct answer: A - Refocus meetings on business outcomes, material risks, decisions needed, and progress against strategic commitments.

Executive engagement is more likely to continue when governance discussions address business outcomes, material exposure, strategic commitments, and decisions requiring leadership authority. More technical detail reduces relevance, excluding business leaders weakens alignment, and suspending meetings eliminates continuing oversight.

Question 24 (CISM1-024)

Correct answer: D - The strategy should be reviewed because its outputs are not reducing risk.

Rising exposure despite completed projects indicates that delivery metrics are not demonstrating the intended outcome, so objectives, assumptions, initiatives, and measures require review. Project completion alone does not establish effectiveness, suspending measurement reduces visibility, and added funding without analysis may reinforce ineffective investments.

Question 25 (CISM1-025)

Correct answer: C - An approved enterprise policy defining principles, authority, accountability, and supporting-document hierarchy.

An enterprise policy establishes authoritative principles, roles, exception authority, and the hierarchy for standards and procedures. Additional procedures cannot resolve missing governance authority, administrator-specific policies would increase inconsistency, and a change freeze does not create a sustainable policy structure.

Question 26 (CISM1-026)

Correct answer: B - Reassess dependencies, risks, and capabilities created by the new service model.

The new operating model changes critical services, stakeholders, dependencies, and risk, so these factors must be reassessed before revising objectives and initiatives. Waiting leaves strategy misaligned, engineers should contribute but not own enterprise strategy, and isolated controls may not address the broader capability changes.

Question 27 (CISM1-027)

Correct answer: A - Evaluate needs against objectives, obligations, risk appetite, architecture dependencies, and expected value.

A defensible roadmap integrates business goals, obligations, approved risk boundaries, architecture dependencies, and expected value when resolving competing demands. Equal allocation ignores material differences, focusing only on existing weaknesses may miss strategic or regulatory priorities, and budget size does not confer enterprise risk authority.